



Payment Card Industry Data Security Standard

Attestation of Compliance for Self-Assessment Questionnaire A-EP

For use with PCI DSS Version 4.0.1

Publication Date: October 2024

Section 1: Assessment Information

Instructions for Submission

This document must be completed as a declaration of the results of the merchant's self-assessment against the *Payment Card Industry Data Security Standard (PCI DSS) Requirements and Testing Procedures*. Complete all sections. The merchant is responsible for ensuring that each section is completed by the relevant parties, as applicable. Contact the entity(ies) to which the Attestation of Compliance (AOC) will be submitted for reporting and submission procedures.

This AOC reflects the results documented in an associated Self-Assessment Questionnaire (SAQ).

Capitalized terms used but not otherwise defined in this document have the meanings set forth in the PCI DSS Self-Assessment Questionnaire.

Part 1. Contact Information

Part 1a. Assessed Merchant

Company name:	WorkUp
DBA (doing business as):	WorkUp
Company mailing address:	Lab / Portfolio
Company main website:	https://victorojeje.xyz
Company contact name:	Victor Ogechukwu Ojeje
Company contact title:	Platform Operator
Contact phone number:	
Contact e-mail address:	ojejevictor@gmail.com

Part 1b. Assessor

Provide the following information for all assessors involved in the assessment. If there was no assessor for a given assessor type, enter Not Applicable.

PCI SSC Internal Security Assessor(s)

ISA name(s):	Not Applicable
Qualified Security Assessor	
Company name:	Not Applicable
Company mailing address:	Not Applicable
Company website:	Not Applicable
Lead Assessor name:	Not Applicable
Assessor phone number:	Not Applicable
Assessor e-mail address:	Not Applicable
Assessor certificate number:	Not Applicable

Part 2. Executive Summary

Part 2a. Merchant Business Payment Channels (select all that apply):

Indicate all payment channels used by the business that are included in this assessment.

☐ Mail order/telephone order (MOTO)

☒ E-Commerce

☐ Card-present

Are any payment channels not included in this assessment?

☐ Yes ☒ No

If yes, indicate which channel(s) is not included in the assessment and provide a brief explanation about why the channel was excluded.

Note: If the organization has a payment channel that is not covered by this SAQ, consult with the entity(ies) to which this AOC will be submitted about validation for the other channels.

Part 2b. Description of Role with Payment Cards

For each payment channel included in this assessment as selected in Part 2a above, describe how the business stores, processes and/or transmits account data.

Channel	How Business Stores, Processes, and/or Transmits Account Data
E-Commerce	WorkUp does not store, process, or transmit cardholder data. Payment collection uses Stripe Embedded Checkout. Card data is entered only inside Stripe-controlled fields. WorkUp systems receive only Stripe tokens/events and never see PAN, expiry, or CVV

Part 2c. Description of Payment Card Environment

Provide a **high-level** description of the environment covered by this assessment.

For example:

- *Connections into and out of the cardholder data environment (CDE).*
- *Critical system components within the CDE, such as POI devices, databases, web servers, etc., and any other necessary payment components, as applicable.*
- *System components that could impact the security of account data.*

WorkUp is a B2B project-management SaaS (\$49/month per workspace). Payment is collected via Stripe Embedded Checkout; cardholder data is entered only inside Stripe-controlled UI elements and never touches WorkUp systems.

Infrastructure: Four segmented Ubuntu 22.04 VMs on a private LAN (192.168.123.0/24) on Proxmox, each running an independent Docker Compose stack:

Frontend VM (192.168.123.21) — nginx static site serving billing.html and loading Stripe.js

Auth VM (192.168.123.22) — Keycloak realm workup

Backend VM (192.168.123.23) — Go/Gin API; creates Stripe checkout sessions, verifies signed webhooks

Observability VM (192.168.123.24) — Grafana / Loki / Prometheus

All inbound public traffic arrives via dedicated Cloudflare Tunnels per segment. No public IP addresses on any VM. The four VMs do not communicate on the internal network; all inter-segment traffic uses public Cloudflare Tunnel URLs only.

Stripe is the PCI DSS Level 1 service provider that handles all cardholder data.

Indicate whether the environment includes segmentation to reduce the scope of the assessment.

(Refer to “Segmentation” section of PCI DSS for guidance on segmentation.)

☒ Yes ☐ No

Part 2. Executive Summary *(continued)*

Part 2d. In-Scope Locations/Facilities

List all types of physical locations/facilities (for example, retail locations, corporate offices, data centers, call centers, and mail rooms) in scope for the PCI DSS assessment.

Facility Type	Total number of locations (How many locations of this type are in scope)	Location(s) of facility (city, country)
<i>Example: Data centers</i>	3	<i>Boston, MA, USA</i>
Home lab / self-hosted environment (Proxmox)	1	Lagos, Nigeria

Part 2e. PCI SSC Validated Products and Solutions

Does the merchant use any item identified on any PCI SSC Lists of Validated Products and Solutions*?

☐ Yes ☒ No

Provide the following information regarding each item the merchant uses from PCI SSC's Lists of Validated Products and Solutions.

Name of PCI SSC validated Product or Solution	Version of Product or Solution	PCI SSC Standard to which product or solution was validated	PCI SSC listing reference number	Expiry date of listing (YYYY-MM-DD)
				YYYY-MM-DD
				YYYY-MM-DD
				YYYY-MM-DD
				YYYY-MM-DD
				YYYY-MM-DD
				YYYY-MM-DD
				YYYY-MM-DD
				YYYY-MM-DD
				YYYY-MM-DD
				YYYY-MM-DD
				YYYY-MM-DD
				YYYY-MM-DD

Part 2. Executive Summary *(continued)*

Part 2f. Third-Party Service Providers

Does the merchant have relationships with one or more third-party service providers that:

Store, process, or transmit account data on the merchant's behalf (for example, payment gateways, payment processors, payment service providers (PSPs), and off-site storage)	☒ Yes ☐ No
Manage system components included in the scope of the merchant's PCI DSS assessment—for example, via network security control services, anti-malware services, security incident and event management (SIEM), contact and call centers, web-hosting services, and IaaS, PaaS, SaaS, and FaaS cloud providers.	☒ Yes ☐ No
Could impact the security of the merchant's CDE (for example, vendors providing support via remote access, and/or bespoke software developers)	☒ Yes ☐ No

If Yes:

Name of service provider:	Description of service(s) provided:
---------------------------	-------------------------------------

For purposes of this document, "Lists of Validated Products and Solutions" means the lists of validated products, solutions, and/or components, appearing on the PCI SSC website (www.pcisecuritystandards.org)—for example, 3DS Software Development Kits, Approved PTS Devices, Validated Payment Software, Point to Point Encryption (P2PE) solutions, Software-Based PIN Entry on COTS (SPoC) solutions, Contactless Payments on COTS (CPoC) solutions, and Mobile Payments on COTS (MPoC) products.

Stripe	Payment processor — Embedded Checkout. Handles all cardholder data collection, processing, and transmission. PCI DSS Level 1 Service Provider.
Cloudflare	CDN, WAF (Custom Rules), Tunnel, and Zero Trust Access. Provides the public edge and protects inbound traffic to all WorkUp services.

Note: Requirement 12.8 applies to all entities in this list.

Part 2. Executive Summary *(continued)*

Part 2g. Summary of Assessment

(SAQ Section 2 and related appendices)

Indicate below all responses that were selected for each PCI DSS requirement.

PCI DSS Requirement *	Requirement Responses			
	<i>More than one response may be selected for a given requirement. Indicate all responses that apply.</i>			
	In Place	In Place with CCW	Not Applicable	Not in Place
Requirement 1:	☒	☐	☐	☐
Requirement 2:	☒	☐	☐	☐
Requirement 3:	☐	☐	☒	☐
Requirement 4:	☐	☐	☒	☐
Requirement 5:	☐	☐	☒	☐
Requirement 6:	☒	☐	☐	☐
Requirement 7:	☒	☐	☐	☐
Requirement 8:	☒	☐	☐	☐
Requirement 9:	☐	☐	☒	☐
Requirement 10:	☒	☐	☐	☐
Requirement 11:	☒	☐	☐	☐
Requirement 12:	☒	☐	☐	☐

** PCI DSS Requirements indicated above refer to the requirements in Section 2 of the SAQ associated with this AOC.*

Part 2. Executive Summary *(continued)*

Part 2h. Eligibility to Complete SAQ A-EP

Merchant certifies eligibility to complete this Self-Assessment Questionnaire because, for this payment channel:

☒	The merchant accepts only e-commerce transactions;
☒	All processing of account data, with the exception of the payment page, is entirely outsourced to a PCI DSS compliant third-party service provider (TPSP)/payment processor;
☒	The merchant's e-commerce website does not receive account data but controls how customers, or their account data, are redirected to a PCI DSS compliant TPSP/payment processor;
☒	If merchant website is hosted by a TPSP, the TPSP is compliant with all applicable PCI DSS requirements (for example, including PCI DSS Appendix A if the TPSP is a multi-tenant hosting provider);
☒	Each element of the payment page(s) delivered to the customer's browser originates from either the merchant's website or a PCI DSS compliant TPSP;
☒	The merchant does not electronically store, process, or transmit any account data on merchant systems or premises, but relies entirely on a TPSP(s) to handle all these functions;
☒	The merchant has confirmed that TPSP(s) are PCI DSS compliant for the services used by the merchant;
☒	Any account data the merchant might retain is on paper (for example, printed reports or receipts), and these documents are not received electronically.

Section 2: Self-Assessment Questionnaire A-EP

Self-assessment completion date:	2026-09-23
Were any requirements in the SAQ unable to be met due to a legal constraint?	☐ Yes ☒ No

Section 3: Validation and Attestation Details

Part 3. PCI DSS Validation

This AOC is based on results noted in SAQ A-EP (Section 2), dated (Self-assessment completion date YYYY-MM-DD).

Based on the results documented in the SAQ A-EP noted above, each signatory identified in any of Parts 3b-3d, as applicable, assert(s) the following compliance status for the merchant identified in Part 2 of this document.

Select one:

☒	Compliant: All sections of the PCI DSS SAQ are complete and all requirements are marked as being either 1) In Place, 2) In Place with CCW, or 3) Not Applicable, resulting in an overall COMPLIANT rating; thereby <i>WorkUp</i> has demonstrated compliance with all PCI DSS requirements included in this SAQ.								
☐	Non-Compliant: Not all sections of the PCI DSS SAQ are complete, or one or more requirements are marked as Not in Place, resulting in an overall NON-COMPLIANT rating, thereby (<i>Merchant Company Name</i>) has not demonstrated compliance with the PCI DSS requirements included in this SAQ. Target Date for Compliance: YYYY-MM-DD A merchant submitting this form with a Non-Compliant status may be required to complete the Action Plan in Part 4 of this document. Confirm with the entity to which this AOC will be submitted <i>before completing Part 4</i>.								
☐	Compliant but with Legal exception: One or more assessed requirements in the PCI DSS SAQ are marked as Not in Place due to a legal restriction that prevents the requirement from being met and all other requirements are marked as being either 1) In Place, 2) In Place with CCW, or 3) Not Applicable, resulting in an overall COMPLIANT BUT WITH LEGAL EXCEPTION rating; thereby (<i>Merchant Company Name</i>) has demonstrated compliance with all PCI DSS requirements included in this SAQ except those noted as Not in Place due to a legal restriction. This option requires additional review from the entity to which this AOC will be submitted. <i>If selected, complete the following:</i> <table border="1"> <thead> <tr> <th>Affected Requirement</th> <th>Details of how legal constraint prevents requirement from being met</th> </tr> </thead> <tbody> <tr> <td> </td> <td> </td> </tr> <tr> <td> </td> <td> </td> </tr> <tr> <td> </td> <td> </td> </tr> </tbody> </table>	Affected Requirement	Details of how legal constraint prevents requirement from being met						
Affected Requirement	Details of how legal constraint prevents requirement from being met								

Part 3a. Merchant Acknowledgement

Signatory(s) confirms:

(Select all that apply)

☒	PCI DSS Self-Assessment Questionnaire A-EP, Version 4.0.1, was completed according to the instructions therein.
☒	All information within the above-referenced SAQ and in this attestation fairly represents the results of the merchant's assessment in all material respects.
☒	PCI DSS controls will be maintained at all times, as applicable to the merchant's environment.

Part 3b. Merchant Attestation

VICTOR OJEJE

Signature of Merchant Executive Officer ↑	Date: 2026-09-23
Merchant Executive Officer Name: Victor Ogechukwu Ojeje	Title: Platform Operator

Part 3c. Qualified Security Assessor (QSA) Acknowledgement

If a QSA was involved or assisted with this assessment, indicate the role performed:

☐ QSA performed testing procedures.

☐ QSA provided other assistance.

If selected, describe all role(s) performed:

Signature of Lead QSA ↑	Date: YYYY-MM-DD
Lead QSA Name:	

Signature of Duly Authorized Officer of QSA Company ↑	Date: YYYY-MM-DD
Duly Authorized Officer Name:	QSA Company:

Part 3d. PCI SSC Internal Security Assessor (ISA) Involvement

If an ISA(s) was involved or assisted with this assessment, indicate the role performed:

☐ ISA(s) performed testing procedures.

☐ ISA(s) provided other assistance.

If selected, describe all role(s) performed:

Part 4. Action Plan for Non-Compliant Requirements

Only complete Part 4 upon request of the entity to which this AOC will be submitted, and only if the Assessment has a Non-Compliant status noted in Section 3.

If asked to complete this section, select the appropriate response for “Compliant to PCI DSS Requirements” for each requirement below. For any “No” responses, include the date the merchant expects to be compliant with the requirement and a brief description of the actions being taken to meet the requirement.

PCI DSS Requirement *	Description of Requirement	Compliant to PCI DSS Requirements (Select One)		Remediation Date and Actions (If “NO” selected for any Requirement)
		YES	NO	
1	Install and maintain network security controls	☐	☐	
2	Apply secure configurations to all system components	☐	☐	
3	Protect stored account data	☐	☐	
4	Protect cardholder data with strong cryptography during transmission over open, public networks	☐	☐	
5	Protect all systems and networks from malicious software	☐	☐	
6	Develop and maintain secure systems and software	☐	☐	
7	Restrict access to system components and cardholder data by business need to know	☐	☐	
8	Identify users and authenticate access to system components	☐	☐	
9	Restrict physical access to cardholder data	☐	☐	
10	Log and monitor all access to system components and cardholder data	☐	☐	
11	Test security systems and networks regularly	☐	☐	
12	Support information security with organizational policies and programs	☐	☐	

* PCI DSS Requirements indicated above refer to the requirements in Section 2 of the SAQ associated with this AOC.

Note: The PCI Security Standards Council is a global standards body that provides resources for payment security professionals developed collaboratively with our stakeholder community. Our materials are accepted in numerous compliance programs worldwide. Please check with your individual compliance-accepting organization to ensure that this form is acceptable in its program. For more information about PCI SSC and our stakeholder community please visit: <https://www.pcisecuritystandards.org/about-us/>.